

PHISHING TRIAGE & ANALYSIS TOOLKIT

Standard Operating Procedures & Frameworks for the Human Firewall

Role: Cybersecurity Analyst Operations Desk

Project Milestone: Project 3 (Detection & Triage Phase)

Batch Certification: 2026

Organization: DecodeLabs Industrial Training Division

1. Executive Summary & Contextual Threat Landscape

The modern enterprise perimeter has migrated definitively away from traditional hardware firewalls and perimeter access lists to the individual user desktop. Human-centric authentication and vector interactions constitute the primary target area for corporate breaches. As validated by global red-team operations and digital forensics telemetry:

80%	40%	82s
BREACHES INVOLVING PHISHING	SIMULATION FAILURE RATE	AVG. TIME TO FIRST CLICK

The Quanta Computer Exploit Case Study: A single threat actor bypassed financial verification algorithms to exfiltrate over \$100 Million from technology conglomerates including Google and Facebook. The attack utilized highly targeted spear-phishing tactics by weaponizing a lookalike domain representing a verified external hardware supplier (Quanta) combined with forged supporting procurement documents. This event underscores that psychological profiling completely neutralizes standard perimeter validation protocols.

2. Threat Taxonomy & Delivery Vectors

Modern social engineering exploits multi-channel infrastructure to enforce malicious payloads. Triage teams must parse threats based on specific classification guidelines:

2.1 Email Hierarchy Targeting

- **Mass Phishing:** High-volume, non-personalized templates mimicking widely deployed consumer brands (e.g., Amazon, PayPal). Telemetry indicates an approximate baseline conversion rate of $P_{\text{click}} \approx 1\%$.
- **Spear Phishing:** High-precision contextual attacks utilizing open-source intelligence (OSINT) scraped from corporate networks and profile aggregators (e.g., LinkedIn). Lures explicitly reference genuine current internal initiatives, software infrastructure, or colleague identities.
- **Whaling:** Absolute precision campaigns focused on C-Suite executives and administrative controllers. The explicit goal is typically Business Email Compromise (BEC) wire execution or highly restrictive M&A data exfiltration.

2.2 Non-Inbox Communication Channels

- **Smishing (SMS):** Short Message Service vector utilizing malicious hyperlinks wrapped inside tracking updates or instantaneous security warnings.
- **Vishing (Voice):** Real-time telephonic social engineering leveraging Caller ID spoofing infrastructure to impersonate IT Helpdesk elements or legal entities.
- **Quishing (QR Codes):** Matrix barcodes embedded in physical materials or inside digital PDF files designed to pivot desktop sessions onto unmanaged mobile environments where complete URL strings are visually truncated.
- **Search Engine Phishing (SEO Poisoning):** Manipulating search index protocols to force lookalike infrastructure above legitimate portals for active credential harvesting.

3. Lookalike Infrastructure & Psychological Exploits

Attackers construct deceptive digital domains using strict visual and infrastructure manipulations to confuse the human eye and technical defenses.

3.1 Technical Domain Disguises

Attack Type	Technical Definition	Enterprise Example
Typosquatting	Registration of common or visually imperceptible typographical errors.	amaz0n.com
Homoglyph Attack	Substitution of visually identical characters from alternate character sets (e.g., Cyrillic).	paypal.com (using Cyrillic 'a')
Combosquatting	Appending security or administrative suffixes directly to a valid brand name.	yourcompany-secure-login.com
Subdomain Trap	Nesting trusted brand patterns within complex multi-layered subdomains. Normal right-to-left parsing identifies the rogue root domain.	www.decode labs . tech . login - update . com
Dangling DNS Takeover	Exploiting stale CNAME infrastructure referencing deleted external cloud storage buckets.	Active subdomain pointing to open bucket asset.

3.2 Cognitive Triggers

All phishing artifacts leverage specific behavioral catalysts to trigger immediate fight-or-flight reactions, effectively bypassing logical verification thresholds:

- **Authority:** Mimicking executive leadership, external enforcement, or strict corporate audit entities to demand absolute compliance.
- **Urgency:** Setting tight operational countdown frames (e.g., "Account termination within 30 minutes") to restrict analytical thinking.
- **Curiosity:** Exploiting knowledge gaps and social interactions (e.g., "Review anonymous internal HR feedback").
- **Fear / Greed:** Leveraging adverse outcomes (legal prosecution) or massive financial arbitrage opportunities.

4. Analyst Standard Operating Procedure (SOP)

Analysts must process all escalated external interactions using this formal technical checklist before determining asset status:

Phase I: Inbound Header Verification Checklist

- ☐ **True Envelope Analysis:** Verify if the hidden <From:>, <Reply-To:>, or <Return-Path:> routing syntax contradicts the trusted friendly text display name.
- ☐ **Authentication Protocol Validation:** Confirm pass flags for SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail), and DMARC (Domain-based Message Authentication, Reporting, and Conformance). Failures require immediate routing to malicious staging.
- ☐ **Message Path Verification:** Audit the sequential line order of the Received: headers to detect fake forwarded conversation chains (FW: text inserts) mimicking local internal origins.

Phase II: Link & Structural Component Audit

- ☐ **Right-to-Left Root Parsing:** Isolate every embedded hyperlink and read strictly from right to left starting past the primary protocol tags (https://) to discover the true top-level domain registry root.
- ☐ **Single Sign-On (SSO) Sandbox Isolation:** Inspect authentication interfaces for Browser-in-the-Browser (BitB) visual traps. Confirm if the window border element shifts cleanly when dragged across screen edges.
- ☐ **Dangerous Payload Scan:** Flag unusual system container extensions (.iso, .js, .scr) or code blocks designed for dynamic HTML smuggling attacks.

5. Phishing Triage Logic & Action Matrix

Triage operators must route classified events through a explicit three-tier triage logic tree to ensure consistent operational mitigation steps:

Triage Classification Node 1: Safe Asset

Criteria: Verified passing marks for SPF/DKIM/DMARC protocols + absolute structural mapping alignment across friendly text identity and true envelope routing variables + no emotional behavioral indicators.

Action: CLOSE TICKET -> Archive standard security incident record.

Triage Classification Node 2: Suspicious Asset

Criteria: Passing core technical authentication configurations, but featuring cognitive high-pressure markers, SaaS platform invoice updates, or multi-vector patterns (e.g., out-of-band deepfake telephone voice prompts).

Action: WARN USER -> Deploy internal corporate header alert banners, prompt verification through verified out-of-band communication loops, and monitor authorization tokens.

Triage Classification Node 3: Malicious Asset

Criteria: Failure of cryptographic verification flags + clear lookalike typosquatting/homoglyph triggers + unprompted MFA authenticator exhaustion vectors + direct instruction to execute anomalous corporate cash routing.

Action: BLOCK & ESCALATE -> Terminate the ingress gateway connection, append rogue infrastructure hosts to central blocklists, and run automated script routines to instantly purge the threat asset from all corporate user mailboxes.